

01 / 現在の状態 / 確認する問い

現状から、最大到達量を問い直す。

この設計書が扱うこと

多数の安全性リスクを広く列挙するのではなく、「1つの認証情報が悪用された場合、確認できた取得経路の範囲で最大何件まで届くか」を評価の中心にします（最大到達量 / Maximum Extraction）。取得量・時間・承認する立場・送信先・例外経路（Exception）に分け、現在の状態から実装できる目標とする状態と実装後の確認条件へ変換します。

確認できる範囲（Assessment boundary）

設計・確認は、提示された取得経路、提供された情報、および確認可能な実装範囲を対象とします。未開示・未把握の経路を含むシステム全体の完全性や、全ての流出経路の不存在を保証するものではありません。

Example Mobility株式会社

事業：カーシェア / レンタカー

保有情報例：氏名、住所、生年月日、電話番号、メール、運転免許証画像、本人確認資料、決済関連情報。実データは使用していません。

現在の状態（Current State）

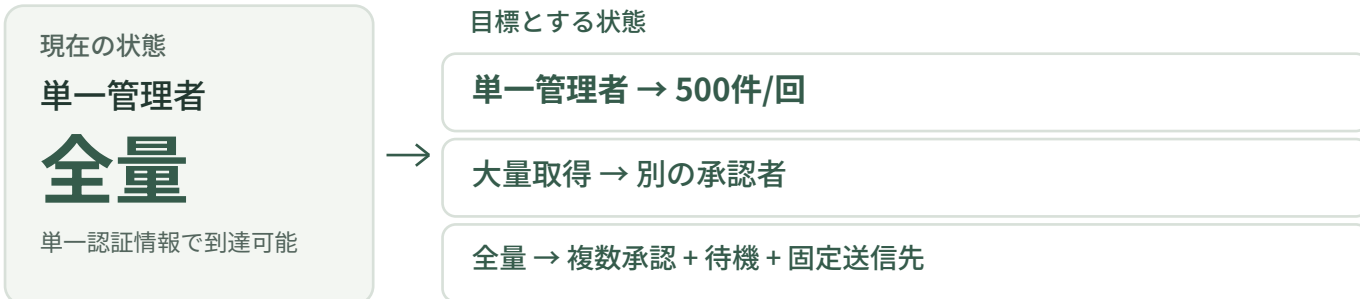
経路	単独操作	1回上限	時間累積	承認	送信先	最大到達量
管理画面（CSV）	可	10,000件	なし	なし	なし	全量
外部連携（API）	可	500件	なし	なし	固定	全量
全件取得	可	全件	即時	1名※	なし	全量

※全件取得（Export）の1名承認は、依頼者が兼ねられる仮設定。独立した別の承認者はいません。画面・連携（CSV/API）で反復取得しても、累積の制限条件がなく全量に届く想定です。

確認する問い（Risk Question）

管理者認証情報が1つ悪用された時、どこまで到達できるか？

何を変えるか（Design Delta） / 現在 → 目標



500件は1回の上限です。24時間累積は2,000件。全量は通常経路から分離します。

段階5（Level 5）は基準となる設計（Reference Architecture）です。一律に求める構成ではなく、業務に不要な制御を理由付きで引き算し、目標とする状態を決めます。

強い認証は侵入可能性を下げますが、認証後の最大到達量は別の設計対象です。

この資料は架空企業を用いた成果物サンプルです。

実際の設計値は、業務要件・既存制御・必要な即時性・責任分担を確認して決めます。

02 / 目標とする状態 / 何を変えるか

取得量に応じて、取得許可の条件を設計する。

目標とする状態（Target State） - 仮設計値

条件	仮設計値 / 取得許可の条件
通常取得	500件/回。通常経路の1回上限。
24時間累積	2,000件。同一主体・同一データ範囲の全経路を、取得時点から遡る24時間で合算。
2,000件超	依頼者と異なる担当者の承認。承認済みの範囲・量を越えて取得しない。
10,000件超	2名以上の独立した承認者 + 待機。依頼者は承認人数へ数えない。
新規送信先	停止 / 再承認。送信先の変更で既存承認を使い回さない。
権限変更直後	大量取得不可。解除条件・待機時間を会社要件で定める。
全量	通常経路では不可。取得済み範囲と業務上の対象データ範囲も見て別の条件で判断する。
緊急全量取得	会社指定の複数承認 + 専用経路 + 時間制約。通常経路への流用不可。

承認は申請者・データ範囲・量・送信先・期限に紐付け、変更時は失効し、取得ごとに再確認します。
待機時間と例外期限は業務要件から設定します。

取得量・時間・承認者・送信先・緊急時の経路を決める（Gate）

時間（Time）	大きな取得ほど待機させる。承認期限と権限変更後の待機も定める。
承認する立場（Seat）	全量に近づくほど単独判断させない。申請者と承認者の権限・認証情報を分離。
送信先（Destination）	固定送信先を基本とし、新規・変更先には別の条件を置く。
取得量（Volume）	1回と累積を、画面・連携・全件取得の経路を跨いで合算。
緊急経路（Recovery）	緊急経路を分離。固有の範囲・期限・承認する立場・証跡を要求し、停止・失効・解除判断を定める。

影響が大きいほど、承認の段階を増やす設計（Escalation Multisig Gate）



最終責任者単独では、前段の申請・通知・待機・必要な独立承認を省略できません。
承認は対象申請・取得許可と、データ範囲・取得量・送信先・申請者・取得許可の種類・期限に紐付けます。
変更・期限切れ・別の取得許可への再利用は無効です。

段階5の代表例であり、唯一の正解ではありません。
承認する立場・承認人数・最終責任者の構成・待機時間は会社ごとに設計します。
最終責任者は1名、または3名のうち2名の承認（2-of-3 Owner Seats）等も可能で、2-of-3を唯一の正解に固定しません。

通常取得は業務に必要なデータ範囲に限定します。
24時間上限だけでは、長期の反復取得による全量到達を抑えたとは扱いません。
取得済み範囲・全量近接の判定も設計・確認対象です。

設計を、確認できる条件へ落とす。

以下は合成データを使う検証計画です。本サンプルでは実装・実行検証はしていません。

実装後の確認（Verification） - 計画 / 未実施

ID	検証する条件	期待する判定 / 保存する証拠
V01	1回上限が効くか	500件の通常取得と501件の要求を比較。 上限超過を止めた判定ログを保存。
V02	分割取得で累積上限を抜けないか	画面・連携（CSV/API）合計2,000件と2,001件を比較。超過時は別 担当者の承認へ。取得時点から遡る24時間で累積を維持。
V03	新規送信先で止まるか	承認後に送信先を変更。旧承認を失効させ、 停止 / 再承認の記録を保存。
V04	承認者1人の侵害で全量へ行けないか	1人分の承認だけでは全量の取得を許可しない。 独立した承認者と申請者除外を確認。
V05	権限昇格直後に大量取得できないか	変更前の承認を引き継がず、大量取得を停止。 解除条件の適用を確認。
V06	緊急経路が通常運用に流用されないか	用途・期限・範囲を越えた例外利用を停止。失効と操作記録を保存。
V07	長期の反復取得で全量に近づかないか	日を跨いでも取得済み範囲と業務上の対象データ範囲を確認。 全量近接時の別条件の判定を検証。

依頼後に受け取る設計書の構成

同じ設計書で、経営側は許容できる最大到達量を、実装側は必要な変更・確認条件を判断できます。全コードの開示は前提にせず、取得経路・上限・承認・送信先・例外などから開始できます。設計書作成を外部依頼し、社内実装後の確認を再度依頼する形も可能です。

設計	経路別の現在の状態、目標値一覧、変更点、取得条件・例外経路の流れ。
責任	承認する立場、固定送信先、停止・失効・解除の担当と決定条件。
確認	検証ケース、実施した範囲の結果・証拠と未確認範囲。実装と設計の差を記録。

実案件では、対象データ範囲・全量の定義、待機時間、独立承認者、送信先、例外期限、累積上限の例外承認権限を確認し、合意した値・前提・未確定事項を設計書に残します。

この資料は架空企業を用いた成果物サンプルです。
実際の設計値は、業務要件・既存制御・必要な即時性・責任分担を確認して決めます。